3 Going online

FULL

07. Your sign-in page (Authelia): how it works and how to manage it

Quick version

No time to read it all? This is the short version. The full guide is below.

- Your sign-in page (Authelia) is one login page at `https://junsgarden.zapto.org/auth`, in front of the garden tools. The front door step (menu `M, 1`) sets it up.
- Two gates, on purpose: you must be signed in, and be in the group `gardeners`, to change the garden.
- One password for the website and the sign-in page: menu `U, 5`.
- Manage people with menu `U`: `2` adds a person who may edit, `3` adds a guest, `4` removes a person, `8` locks everything down.
- Stronger: a phone code (two-factor). Change `one_factor` to `two_factor` in `local/authelia/configuration.yml`, then `docker compose restart authelia`.
- Locked out after wrong passwords? Wait 10 minutes.

What it is

SSO means "single sign-on": one login page in front of several tools. Yours is **Authelia**, at `https://junsgarden.zapto.org/auth`. The front door step (menu `M, 1`) sets it up for you. This guide explains what it does and how to manage it. You never need to edit its files by hand.

How a visit to the garden tools works

```
you open /beds/plan
   -> Caddy asks Authelia: "is this person signed in, and in the group
'gardeners'?"
        no  -> you are sent to /auth to sign in, then back to /beds/plan
        yes -> Caddy passes the visit on, with your email in X-Auth-Email
   -> the garden tools check that email again (BEDS_ALLOWED_EMAILS)
```

Two gates, on purpose: being signed in is not the same as being allowed to change the garden. Caddy also deletes any `X-Auth-Email` a visitor sends themselves, so nobody can pretend to be you.

The website keeps its own login for editing plants (`/login.php`). The menu gives you **one password for both** (menu `U`, `5`).

Who can sign in: menu `U` (Users and access)

Choice	What it does
1 Who can sign in	Lists website logins and sign-in page accounts, and who is signed in now
2 Add a person who may EDIT	Website login + sign-in page + garden tools. You type their first password; they can change it later.
3 Add a GUEST	A sign-in page account in the group `guests`. Guests can sign in, but the garden tools are for `gardeners` only. Use it later for pages you choose to share.
4 Remove a person	Takes away every login they have and signs them out
5 Change a password	Yours or anyone's
6 Sign everybody out	Everyone must sign in again

Choice	What it does
7 SSH keys	Which other computers can open this computer's terminal. Remove any you do not recognise.
8 LOCK DOWN	Only you remain; new passwords and secrets; everyone signed out; then the SSH keys

You are the administrator. Nobody else has an account unless you add one.

Where its settings live

`local/authelia/` (only you can read it): - `configuration.yml`: the rules (made by the front door step from your web name). - `users.yml`: the accounts. Passwords are stored only as Argon2 hashes. - `db.sqlite3`: sign-in history and two-factor devices. - `notification.txt`: if email is not set up, messages (like a two-factor setup link) are written here instead.

Its three secret keys are in `.env`, made by the setup.

Make it stronger: a phone code (two-factor)

1. In `local/authelia/configuration.yml` change `policy: 'one_factor'` to `policy: 'two_factor'`. (The one place you edit a file; `nano` is fine: `sudo nano local/authelia/configuration.yml`, save with `Ctrl+O`, `Enter`, `Ctrl+X`.)
2. Restart the sign-in page so it reads the new rule: `docker compose restart authelia`. (The menu keeps `two_factor` when it writes this file again: front door, email, subdomains.)
3. Sign in at `/auth`. It offers to register a phone app (any authenticator app works). If email is not set up, the link is in `local/authelia/notification.txt`.

Official guide: https://www.authelia.com/configuration/second-factor/introduction/

Ideas for later

- **Protect more tools.** Add a rule in `configuration.yml` and a `forward_auth` block in Caddy (copy the `/beds` one in `docker/caddy/Caddyfile.template`).
- **A web page for managing users** (instead of menu `U`): Authelia can read its users from **LLDAP**, a small user directory with its own web admin page. That is an advanced project: https://github.com/lldap/lldap and https://www.authelia.com/integration/ldap/introduction/.

If something goes differently

What you see	What to do
Sent back to the sign-in page again and again	The web name in the settings must match the address you use. Run the front door step again (menu `M`, `1`).
"Forbidden" after signing in	Your account is not in the group `gardeners`, or your email is not in the garden tools' list. Menu `U`, `1` shows both. Set your password again (menu `U`, `5`) to fix the group.
The sign-in page does not start	`docker logs garden-auth`: it names the setting it does not like. Run the front door step again.
Locked out after wrong passwords	Wait 10 minutes (5 wrong tries in 2 minutes locks the name for 10 minutes).

Read more (official)

- Authelia: https://www.authelia.com/overview/prologue/introduction/
- With Caddy: https://www.authelia.com/integration/proxies/caddy/
- Caddy forward_auth: https://caddyserver.com/docs/caddyfile/directives/forward_auth

Back to the guides.

loved.
endured.
never forgotten.